

waph

Public Respository for Web Application Programming and Hacking course -
Dr. Phu Phung

WAPH-Web Application Programming and Hacking

Instructor: Dr. Phu Phung

Student

Name: Nick Fishman

Email: fishmane@mail.uc.edu

Short-bio: Nick Fishman is an electrical engineering student with a specific interest in hardware and circuits.

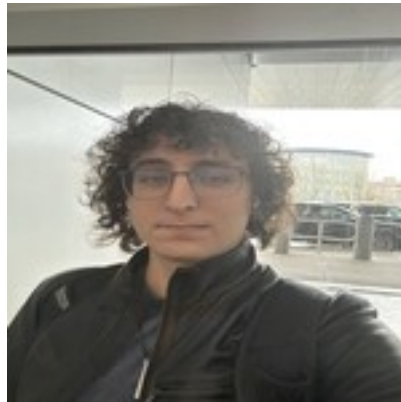


Figure 1: Nick's headshot

Repository Information

Repository's URL: <https://github.com/NickFishman04/waph.git>

This is a private repository for Nick Fishman to store all code from the course.
The organization of this repository is as follows.

Hackathon 2

###Level 0:

###Level 1:

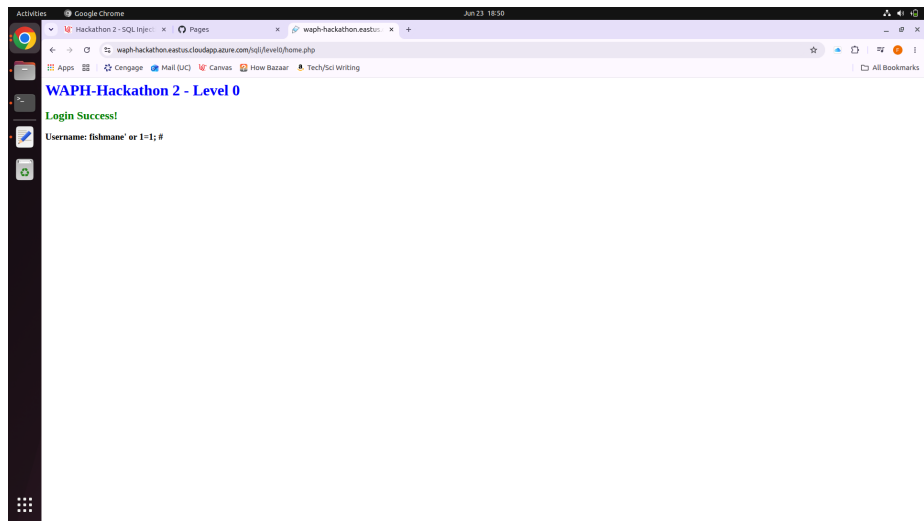


Figure 2: Level 0

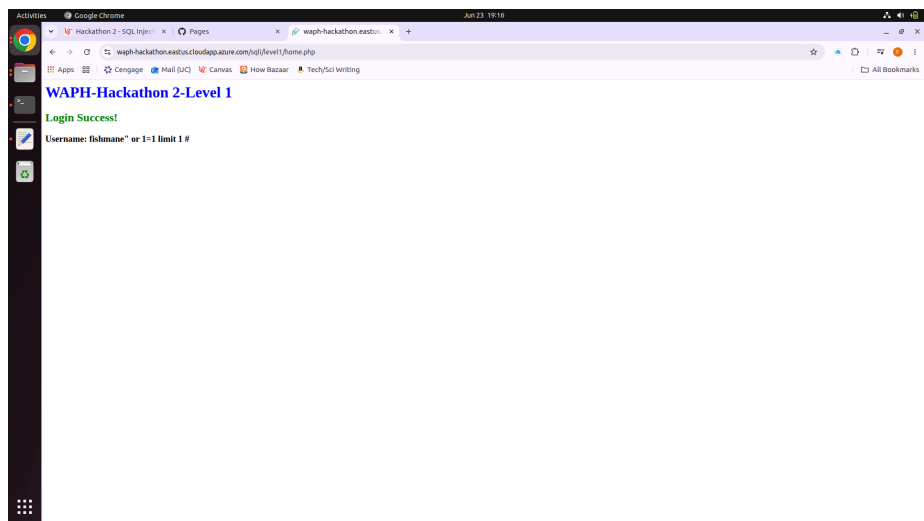


Figure 3: Level 1

####Injection payload:

fishmane" or 1=1 limit 1 #

####Back-end SQL string:

SELECT * FROM users WHERE username = "username"ANDpassword = md5('password')

####Level 2:

####Subtask a:

The product.php page takes an id parameter in the URL (product.php?id=1), which drives a database query to display product info (id, product, price).

If you append a single quote to the parameter, like so: product.php?id=1' You get a fatal error, such as: Fatal error: Uncaught mysqli_sql_exception: You have an error in your SQL syntax; ... near ''' at line 1 in /var/www/html/sqli/level2/product.php:31

This proves there is a vulnerability because the inverted comma was inserted directly into the SQL query without sanitization. If it can get through, that means that an attack could very easily do so as well.

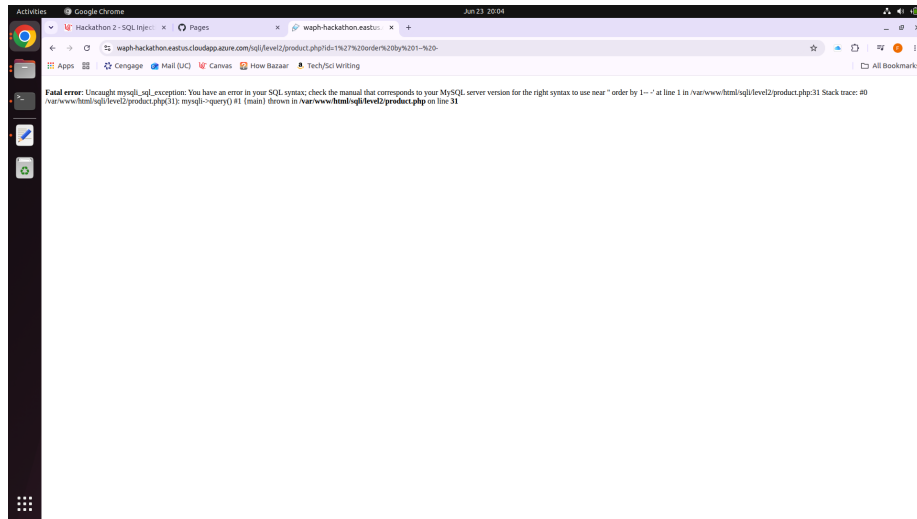


Figure 4: Error Code

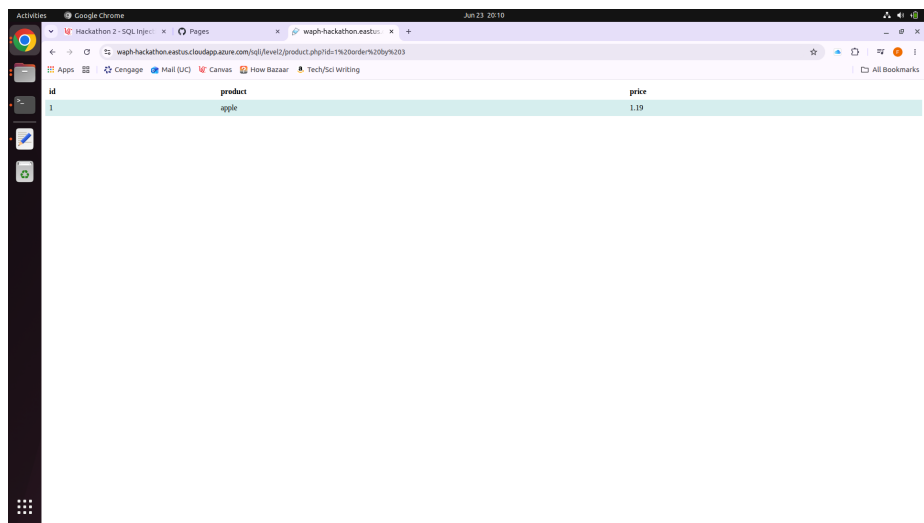
####Subtask b:

#####i)

There are 3 columns for apple, as evidence by the below screenshot.

#####ii)

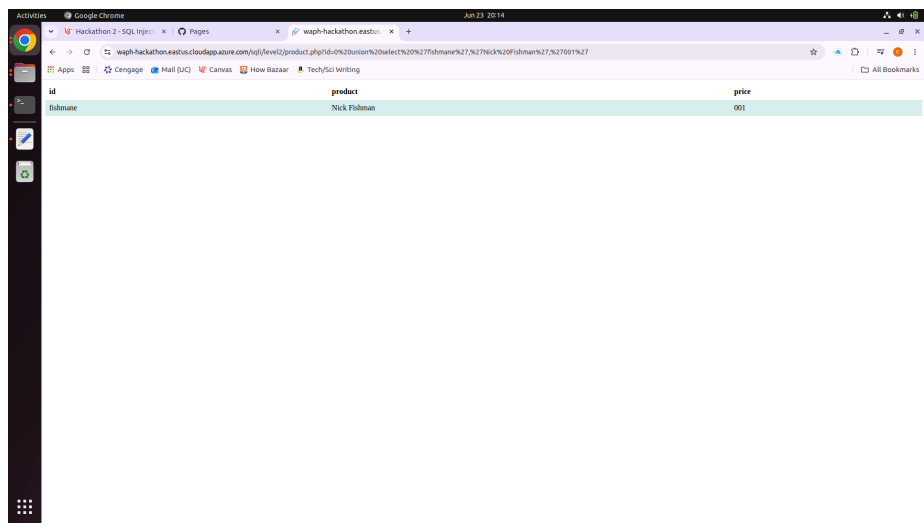
#####iii)



A screenshot of a web browser window showing a table with three columns: id, product, and price. The first row of data shows the value 1 for id, apple for product, and 1.19 for price.

id	product	price
1	apple	1.19

Figure 5: Columns for apple



A screenshot of a web browser window showing a table with three columns: id, product, and price. The first row of data shows the value fishname for id, Nick Fishman for product, and 001 for price.

id	product	price
fishname	Nick Fishman	001

Figure 6: My username, name, and section in the table

	product	price
login	loginname	wagh_hackathon
login	password	wagh_hackathon
products	id	wagh_hackathon
products	name	wagh_hackathon
products	price	wagh_hackathon

Figure 7: Database schema extraction

#####iv)

	product	price
admin	80578edf94506c069bc5b876a05c5a4	3.00
test	e99a1842b3b8452605378922403	3.00

The passwords are still in unsalted md5 format, so I cracked both hashes using an online MD5 lookup service (CrackStation). The below image shows qwerty cracked, and the other value turns out to be abc123.

#####Subtask c:

Labs

Hands-on exercises in lectures

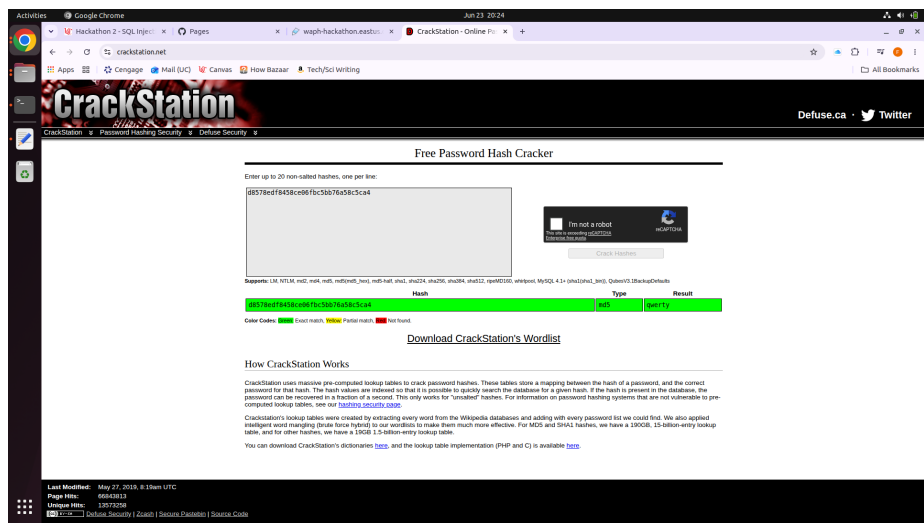


Figure 8: Crackstation showing qwerty cracked

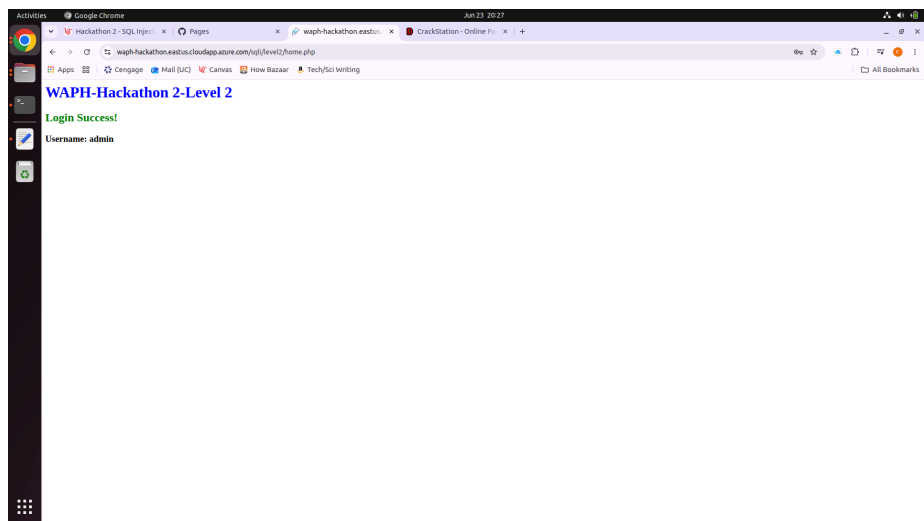


Figure 9: Level 2

- Lab 0: Development Environment Setup
- Lab 1: Foundations of the Web
- Lab 2: Front-end Web Development

Hackations

- Hackathon 1: Cross-site Scripting Attacks and Defenses
- Hackathon 2: SQL Injection Attacks

Individual Projects

- Individual Project 1: Professional Profile Website and API Integration

Team Project